Security Levels in ISA-99 / IEC 62443

Summary

- **Assessment of the security protection of a plant**
  - A *Security Protection Level* has to be assessed in a *plant in operation*
  - A Protection Level requires both:
    - The *fulfillment of the policies and procedures* by the asset owner according to a Security Management System (Series 2)
      and
    - The *fulfillment of a Security Level of the solution* operated by the asset owner to control the plant (Series 3)
  - Proposal:
    - Assess the fulfillment of the *policies and procedures* according to the *CMMI model*
    - Assess the *functional capabilities* of the solution according to the *SLs*
    - Define *Protection Levels (PLs)as a combination of both*
- **Assessment of the security capabilities of control systems and components**
  - There is *no direct relationship* between *Capability SLs* as currently defined and *component capability levels*
  - There is *no contribution of levels of the product development process* to *component capability levels*
  - Proposal:
    - Control Systems:
      - Assess the *functional capabilities* according to the *Capability SLs* (already described in the SAL vector concept)*. No explicit requirements to the components.*
    - Components:
      - Specify the *product development requirements without any level*
      - Assess the *fulfillment of the product development requirements* according to the *CMMI model*
      - Assess the *functional capabilities* of the component according to the *Component Feature Levels*
      - Define *Component Capability Levels (CCLs)* as a *combination of both*

Security Levels in ISA-99 / IEC 62443

Outline

1. ISA-99 / IEC 62443 documents addressing policies and procedures vs. functional requirements

2. Assessment of protection levels of a plant
   - Solution vs. control system
   - Plant life cycle and product development
   - Requirements for the protection of a plant
   - The SLs concept is coherent for a solution and a control system
   - Proposal for Protection Levels (PLs)

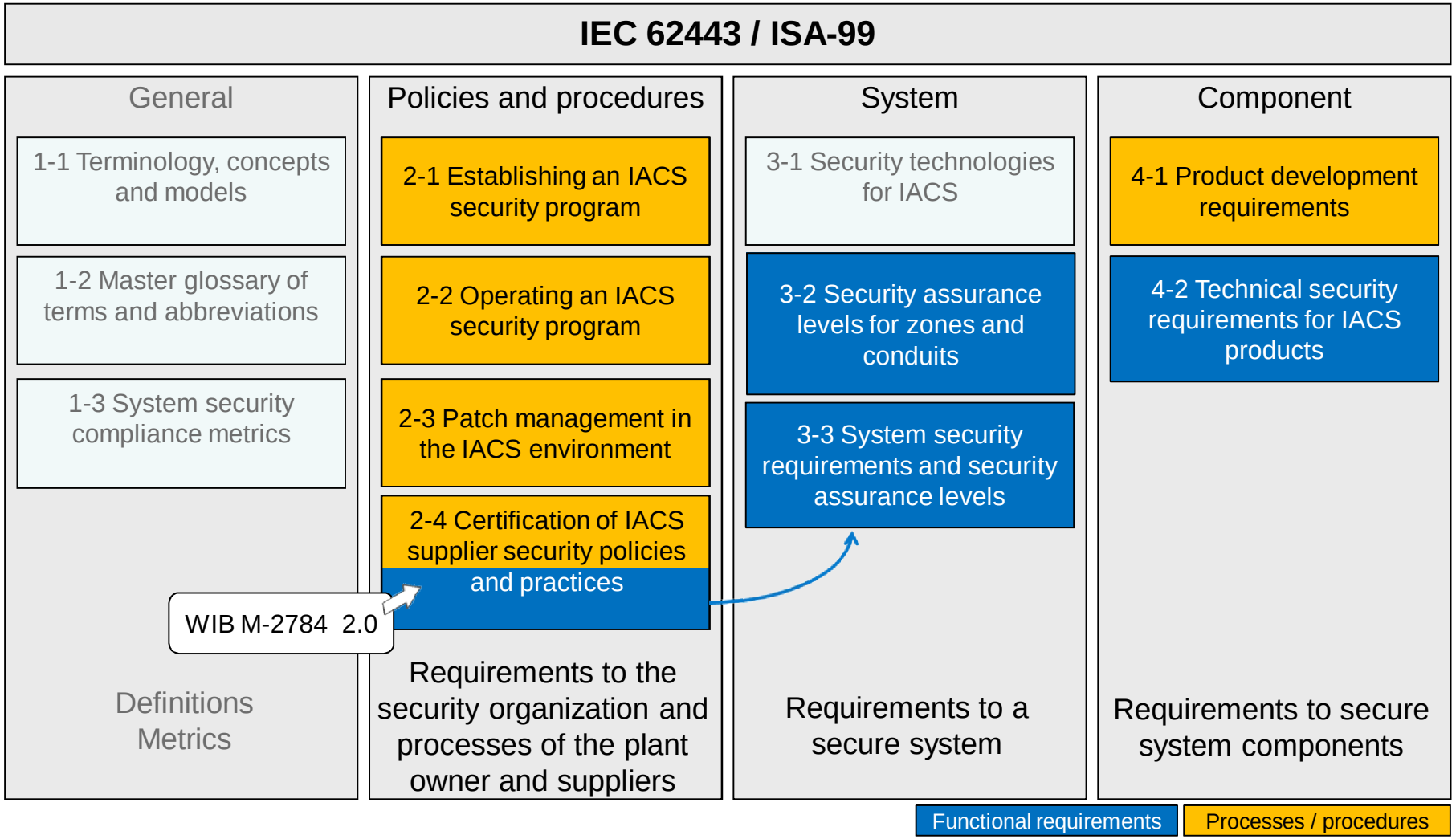
3. Assessment of security capabilities of control systems and components
   - No direct relationship between capability SLs and Component Capability Levels (CCL)
   - No contribution of levels of the Product Development Requirements to the CCL
   - Proposal for Componet Capability Levels (CCLs)

4. Summary if ISA-99 / IEC 62443 relevant document for the various assessments types

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

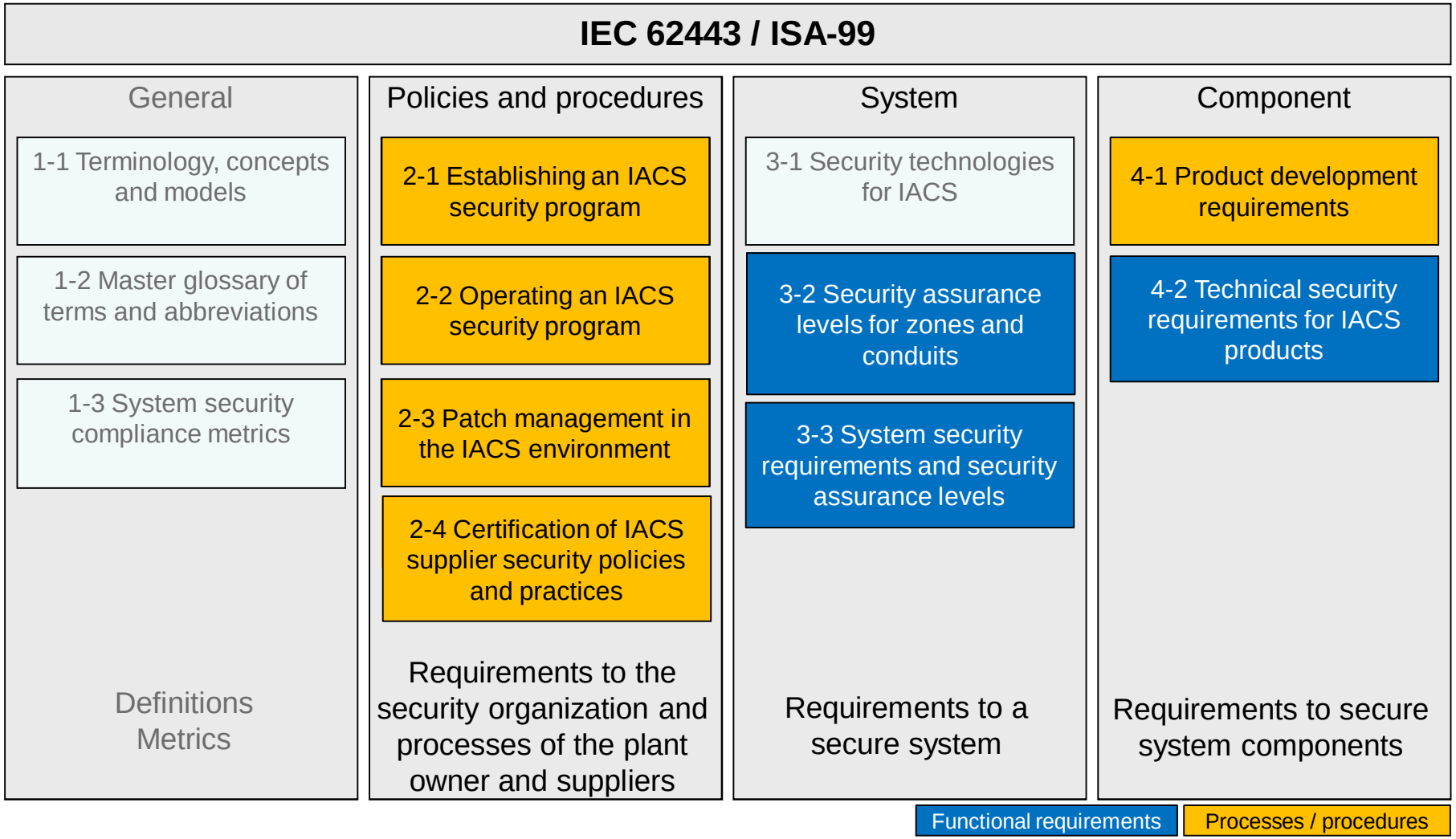
ISA-99 / IEC 62443 covers requirements on processes / procedures as well as functional requirements



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

ISA-99 / IEC 62443 covers requirements on processes / procedures as well as functional requirements



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Outline

1. ISA-99 / IEC 62443 documents addressing policies and procedures vs. functional requirements

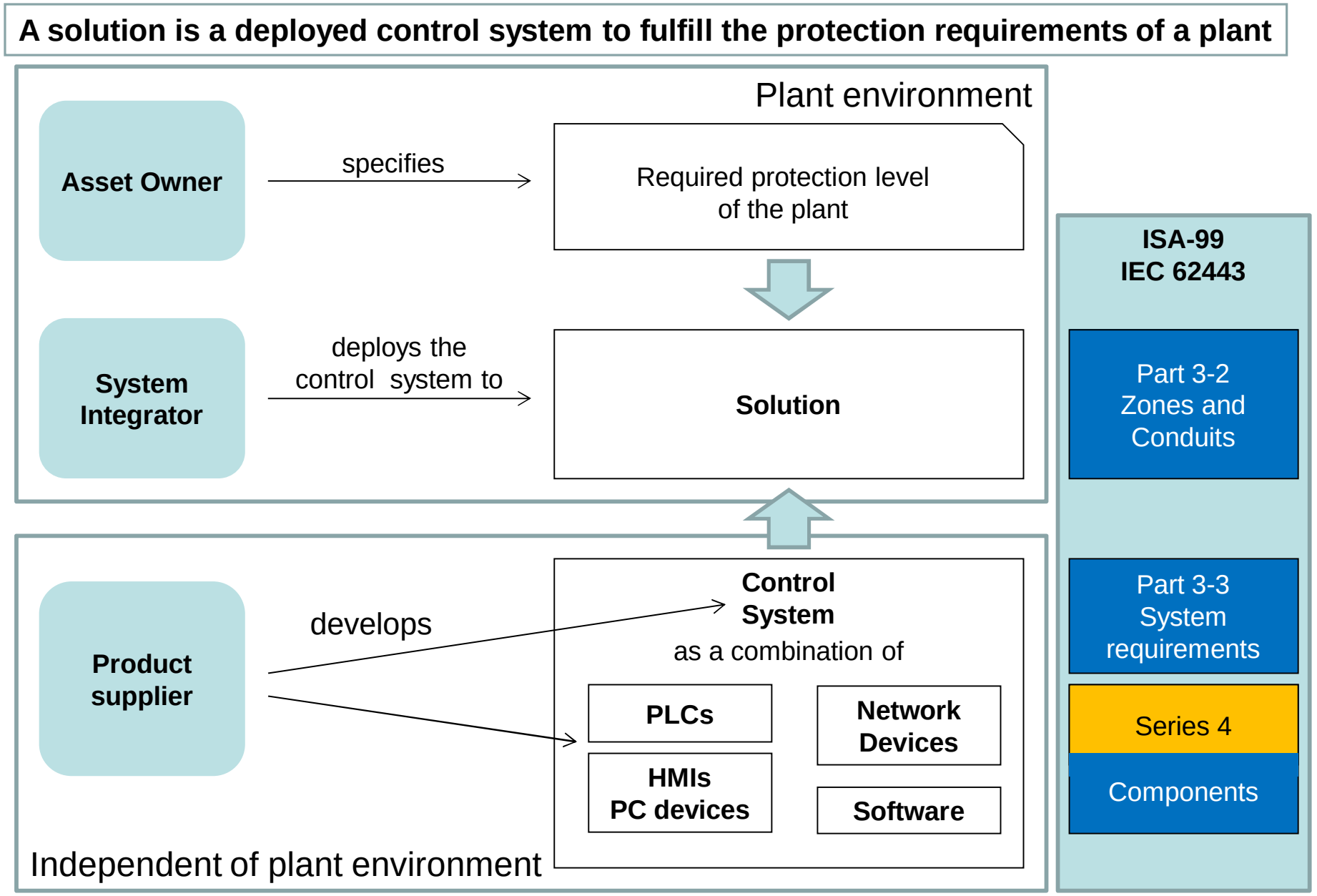
2. Assessment of protection levels of a plant
   - Solution vs. control system
   - Plant life cycle and product development
   - Requirements for the protection of a plant
   - The SLs concept is coherent for a solution and a control system
   - Proposal for Protection Levels (PLs)

3. Assessment of security capabilities of control systems and components
   - No direct relationship between capability SLs and Component Capability Levels (CCL)
   - No contribution of levels of the Product Development Requirements to the CCL
   - Proposal for Componet Capability Levels (CCLs)

4. Summary if ISA-99 / IEC 62443 relevant document for the various assessments types

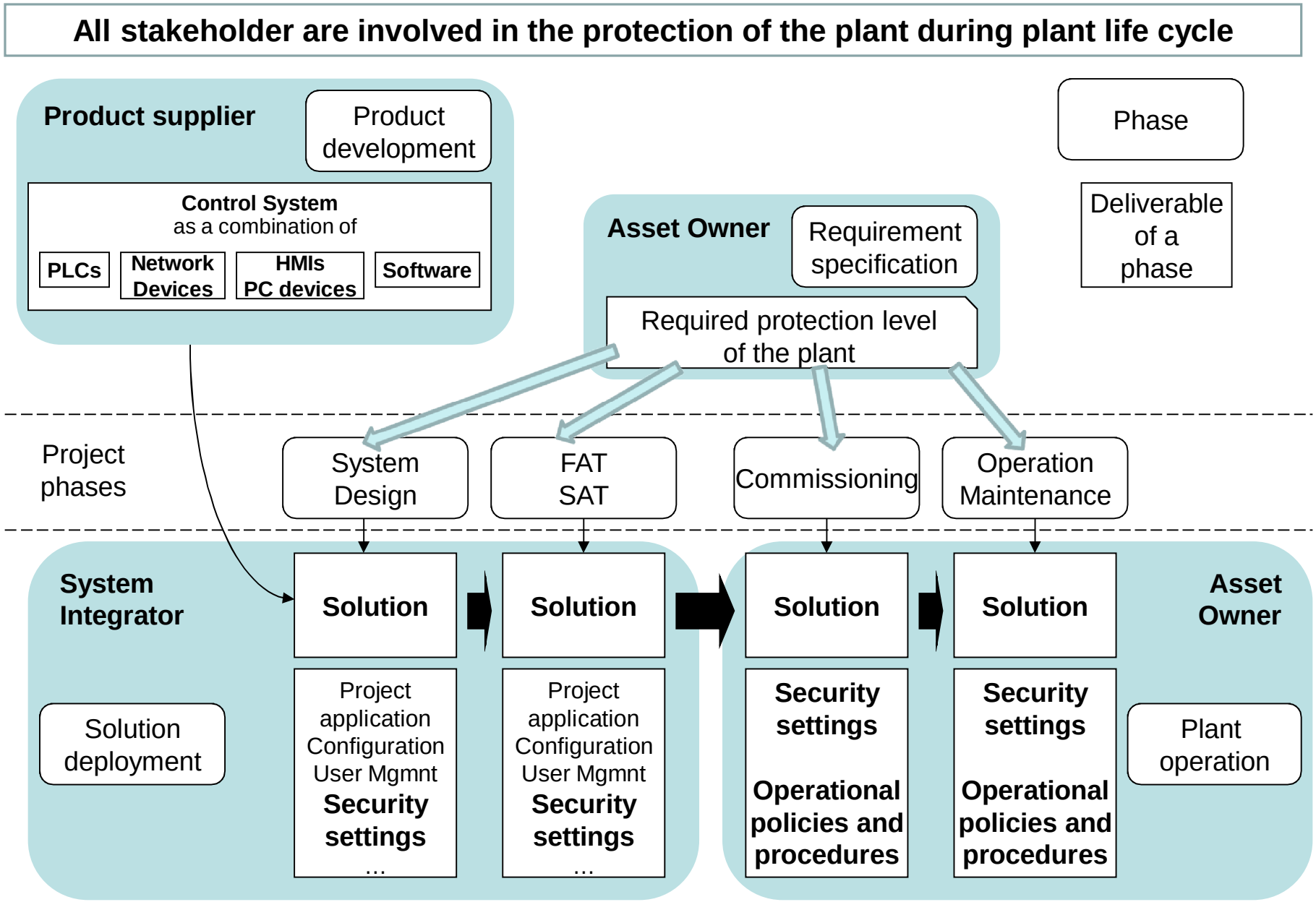
Pierre Kobes

Security Levels in ISA-99 / IEC 62443



Pierre Kobes

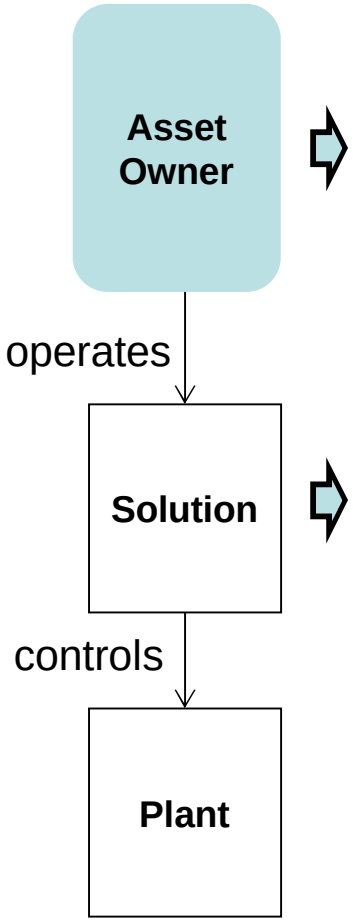
Security Levels in ISA-99 / IEC 62443



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

A Security Protection Level has to be assessed in a plant in operation



Protection Level

Has the appropriate **policies and procedures** in place
-> Security Management System
to operate in a secure fashion a solution

+

Fulfills the **functional capabilities** required by the target protection level of the plant
-> Security Level

ISA-99
IEC 62443

Series 2

Policies and Procedures

Series 3

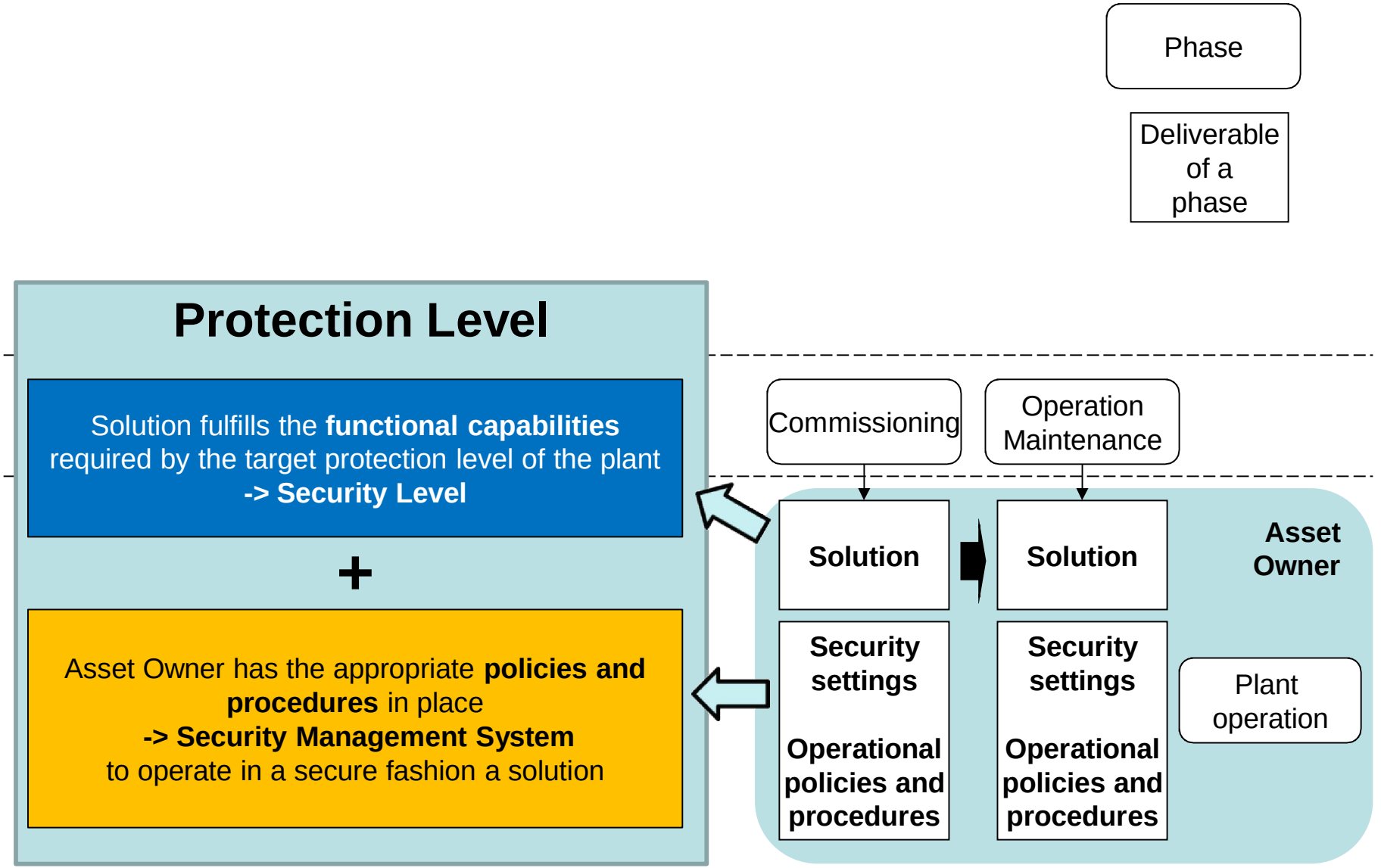
System

A Protection Level requires
Fulfillment of policies and procedures
AND
Fulfillment of a Security Level of the solution

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

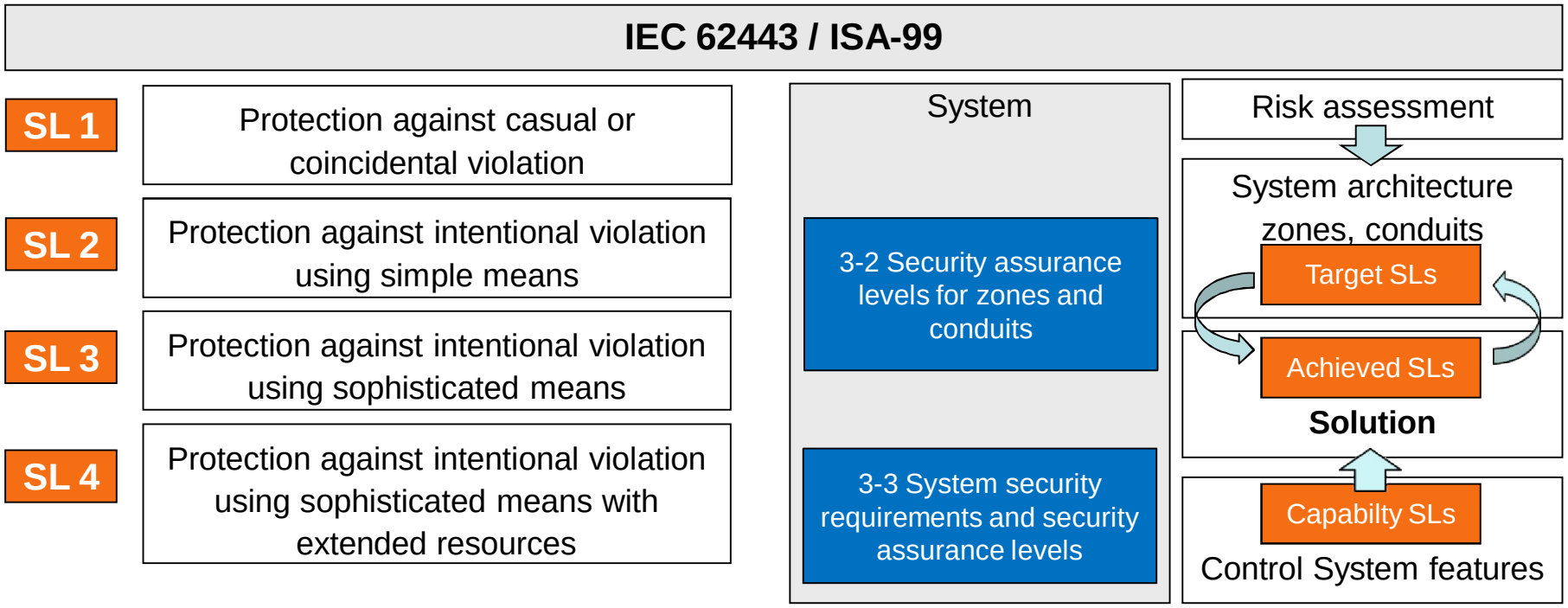
An assessment of the protection level is mainly relevant in a plant in operation



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

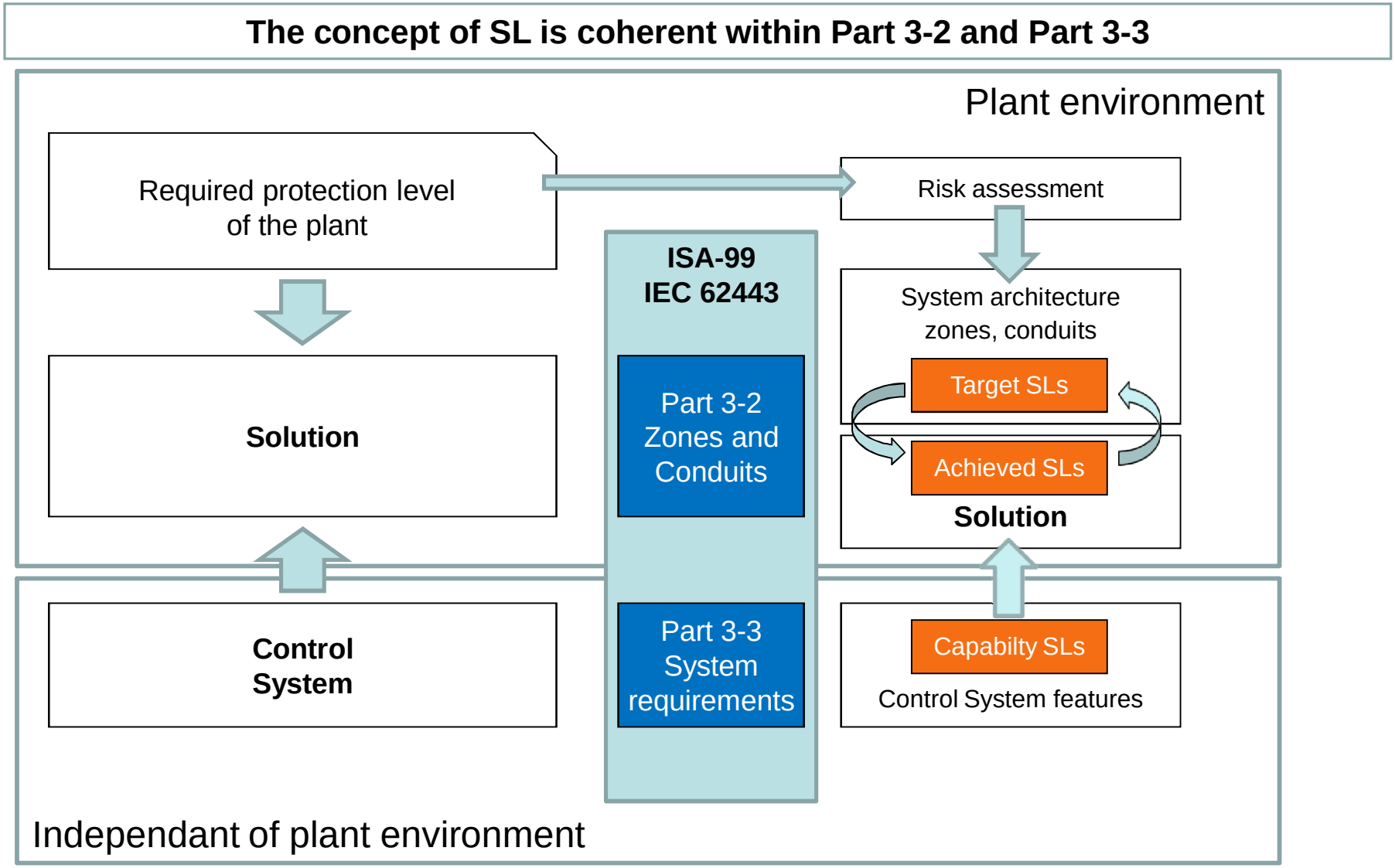
The concept of SL applies to a solution and a control system



The concept of SL is coherent within Part 3-2 and Part 3-3:

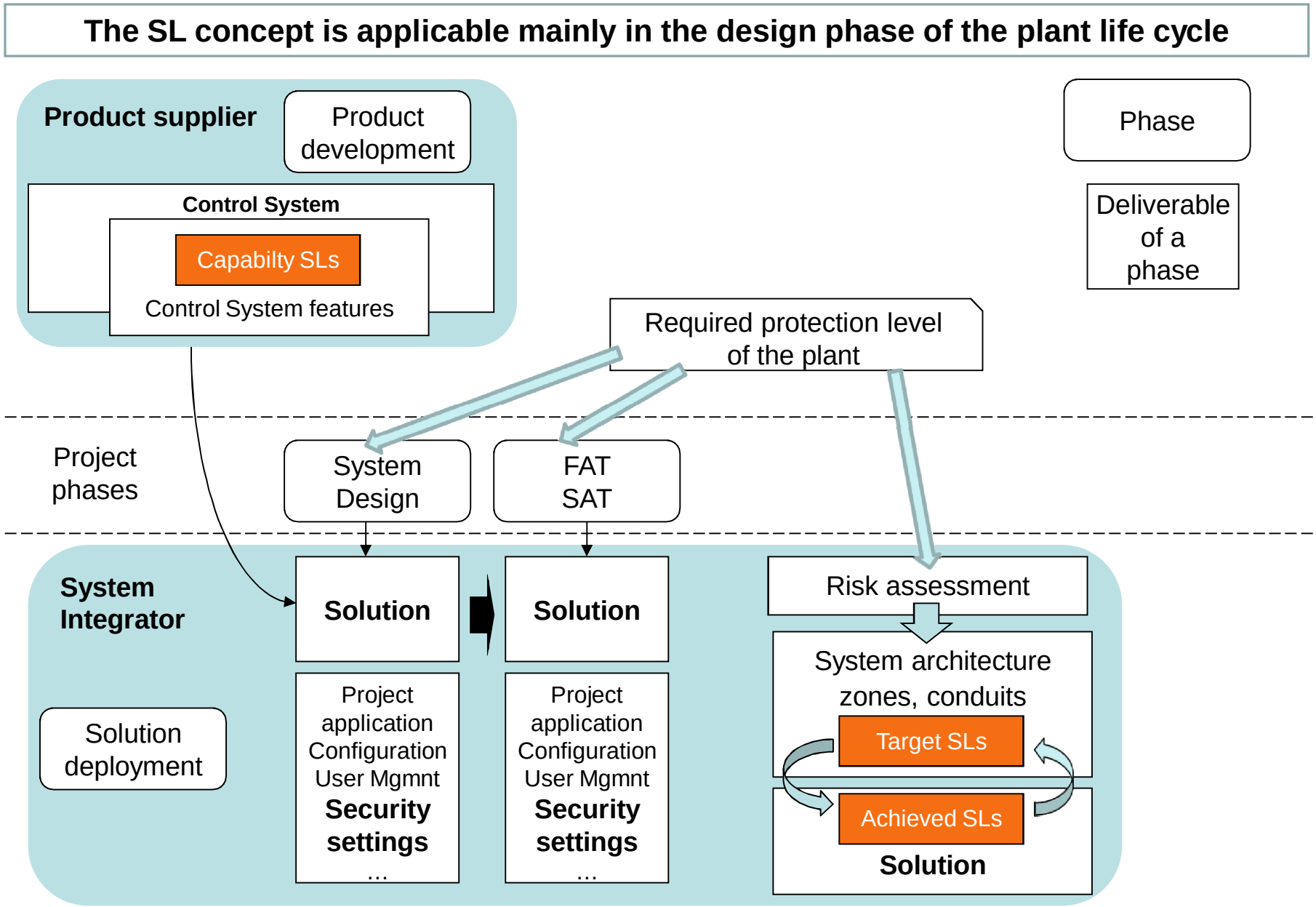
1. **Part 3-2: asset owner / system integrator define zones and conduits with target SLs**
2. **Part 3-3: product supplier provides system features according to capability SLs**
3. **In the project design phase capability SLs are deployed to match target SLs**

Security Levels in ISA-99 / IEC 62443



Pierre Kobes

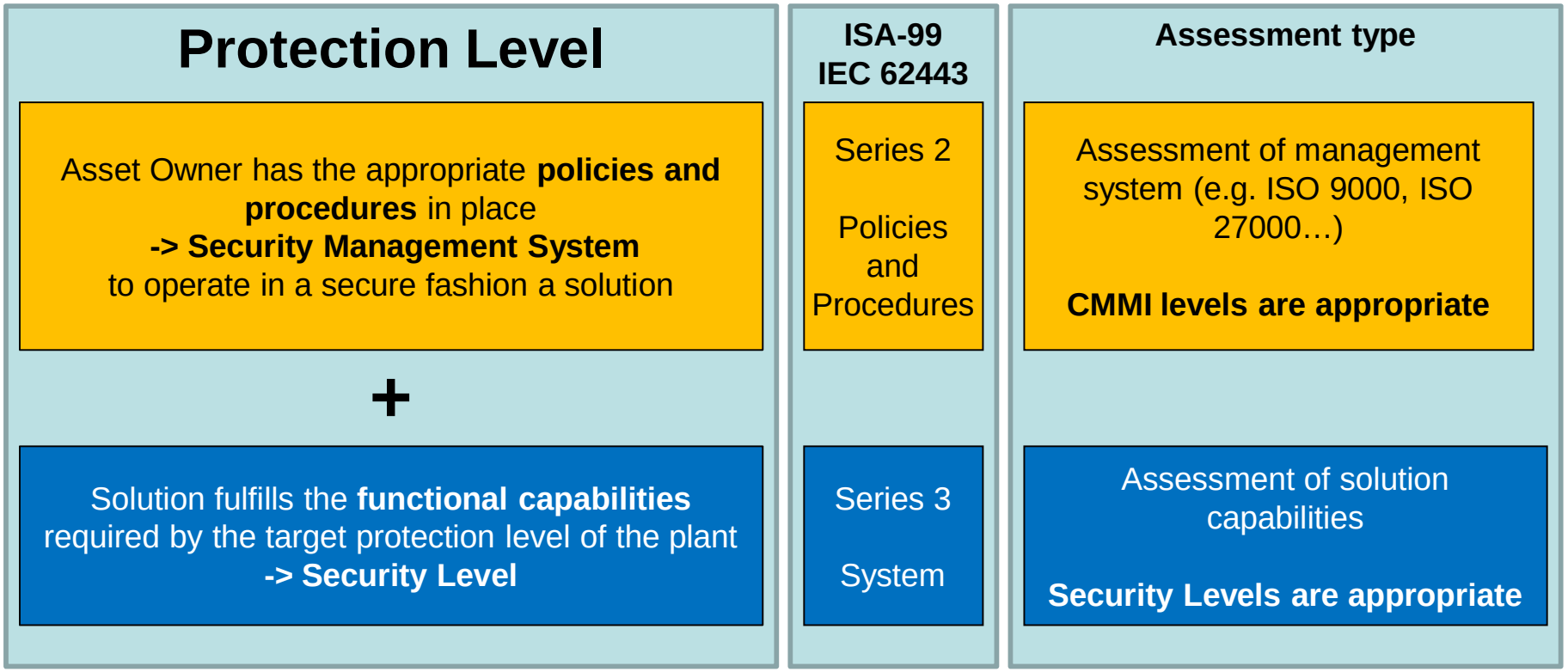
Security Levels in ISA-99 / IEC 62443



Pierre Kobes

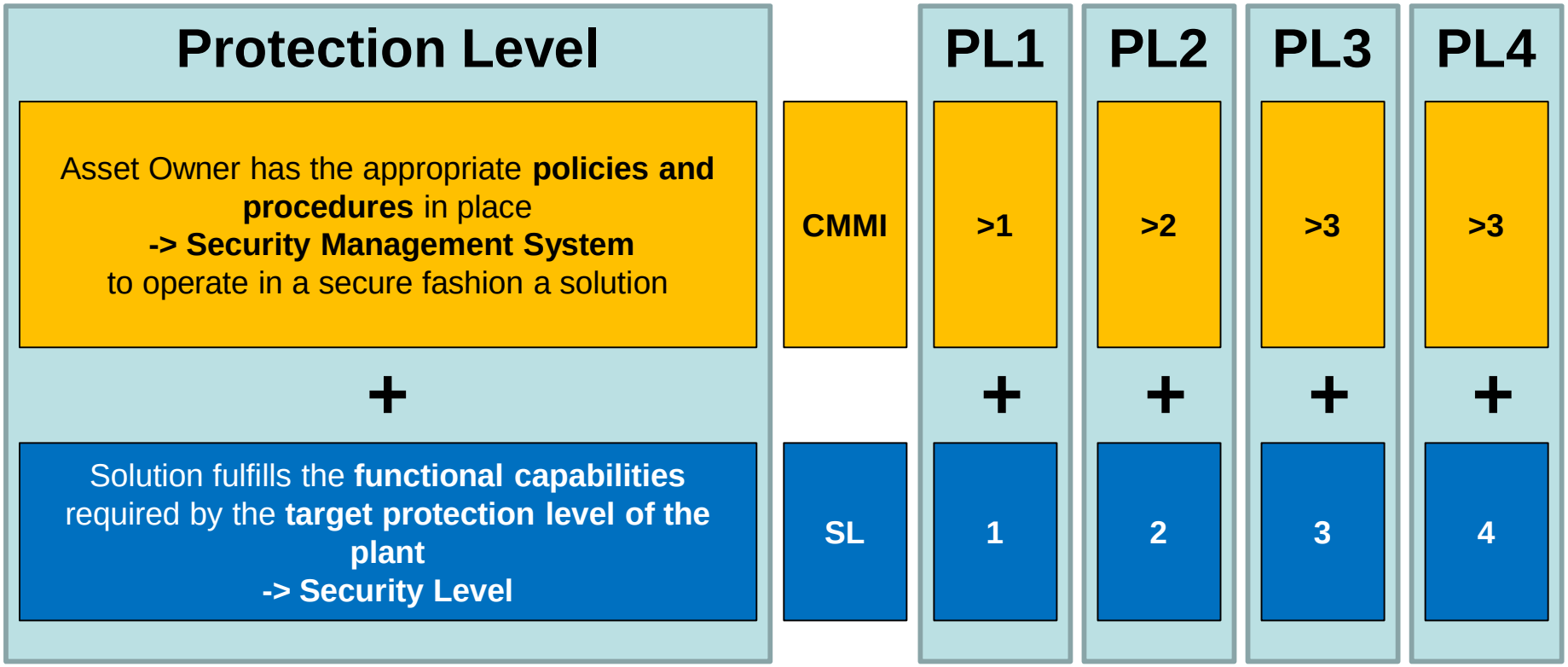
Security Levels in ISA-99 / IEC 62443

A protection level can only be assessed in plant in operation



Security Levels in ISA-99 / IEC 62443

Proposal for the assessment of protection levels



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Outline

1. ISA-99 / IEC 62443 documents addressing policies and procedures vs. functional requirements

2. Assessment of protection levels of a plant
   - Solution vs. control system
   - Plant life cycle and product development
   - Requirements for the protection of a plant
   - The SLs concept is coherent for a solution and a control system
   - Proposal for Protection Levels (PLs)

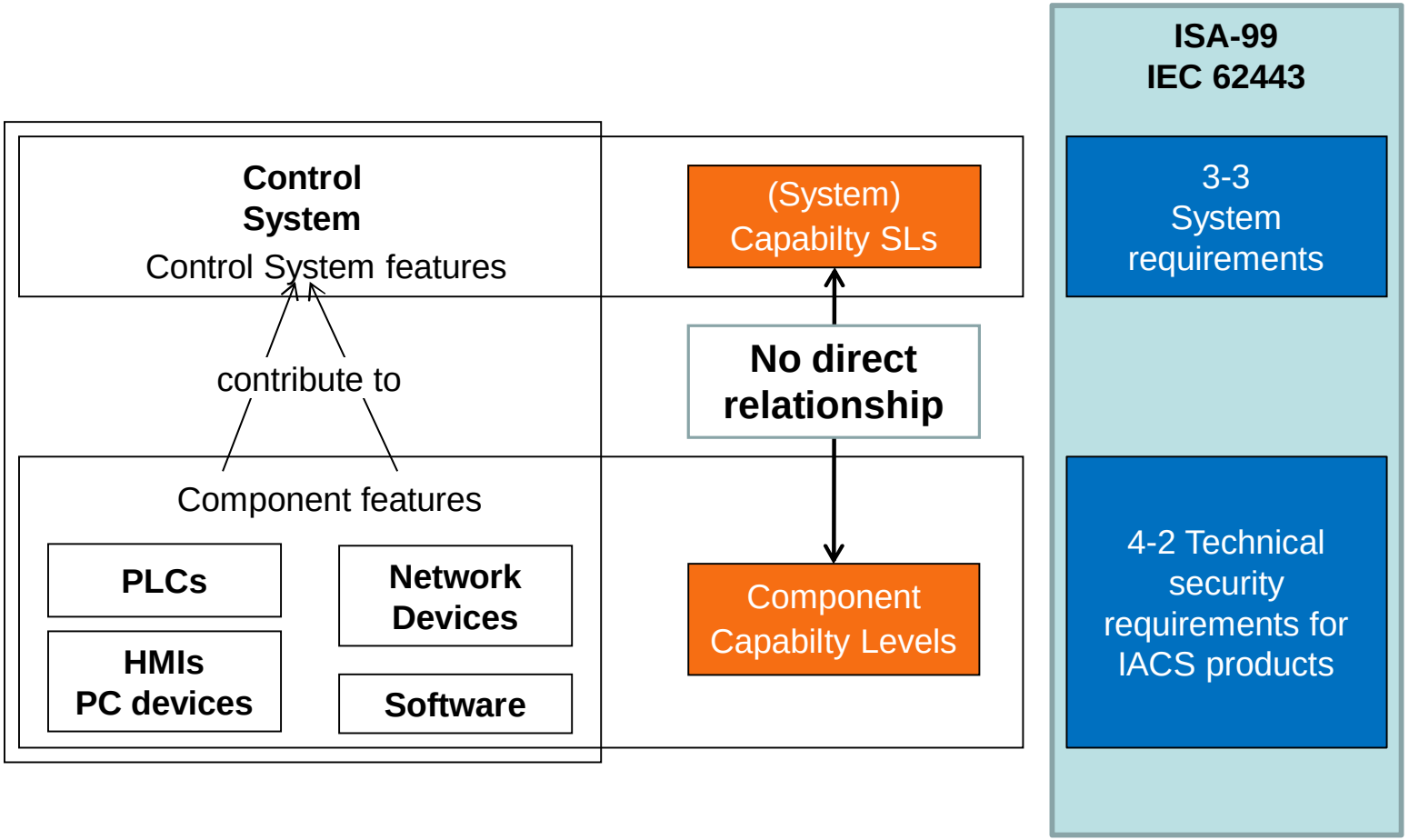
3. Assessment of security capabilities of control systems and components
   - No direct relationship between capability SLs and Component Capability Levels (CCL)
   - No contribution of levels of the Product Development Requirements to the CCL
   - Proposal for Componet Capability Levels (CCLs)

4. Summary if ISA-99 / IEC 62443 relevant document for the various assessments types

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Control system features are often realized by a combination of component features

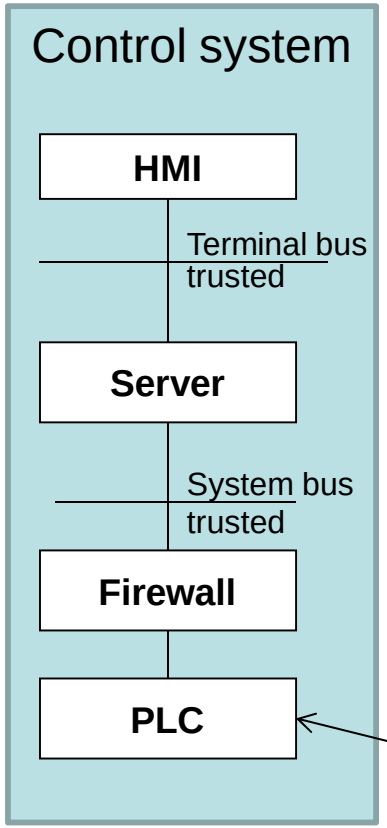


There no direct relationship between
Component Capability Levels and (System) Capability SLs

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Example from Identification and Authentication Control
There no direct relationship between
Component Capability Levels and (System) Capability SLs



Extract of ISA-99.03.03, Draft 4

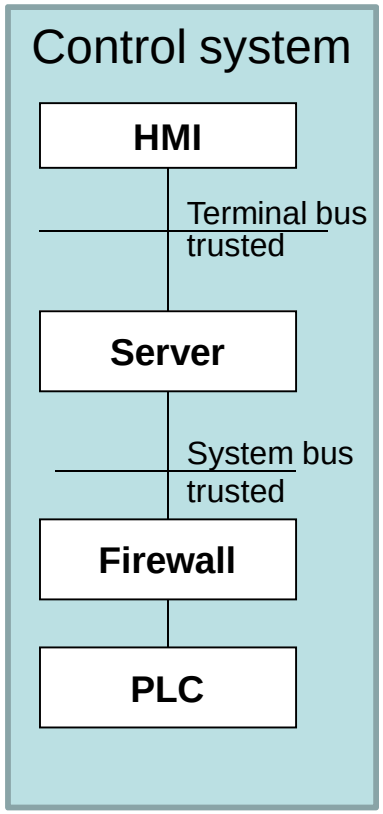
System Requirement	SL
SR 1.1 The control system shall provide the capability to identify and authenticate all users (humans, software processes and devices). This capability shall enforce such identification and authentication on all interfaces which provide access to the control system to support segregation of duties and least privilege in accordance with applicable security policies and procedures.	1
SR 1.1 RE 1 The control system shall provide the capability to uniquely identify and authenticate all users (humans, software processes and devices)	2
SR 1.1 RE 2 The control system shall provide the capability to employ multifactor authentication for human user access to the control system via an untrusted network (see 4.12, SR 1.10 – Access via untrusted networks).	3
SR 1.1 RE 3 The control system shall provide the capability to employ multifactor authentication for all human user access to the control system.	4

PLC has no user management. Has a managed communication to the HMI and can only be accessed via the HMI device.
-> Regarding SR 1.1 the PLC has a low Component Capability Level

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Example from Identification and Authentication Control



Case 1	SL
HMI fulfills only SR 1.1	1
PLC has no user management. Has a managed communication to the HMI and can only be accessed via the HMI device. -> Regarding SR 1.1 the PLC has a low Component Capability Level	

Case 2	SL
HMI fulfills SR 1.1 and RE 1 and has multifactor authentication	4
PLC has no user management. Has a managed communication to the HMI and can only be accessed via the HMI device. -> Regarding SR 1.1 the PLC has a low Component Capability Level	

Different capability SLs can be realized with the same Component Capabilty Level of the PLC

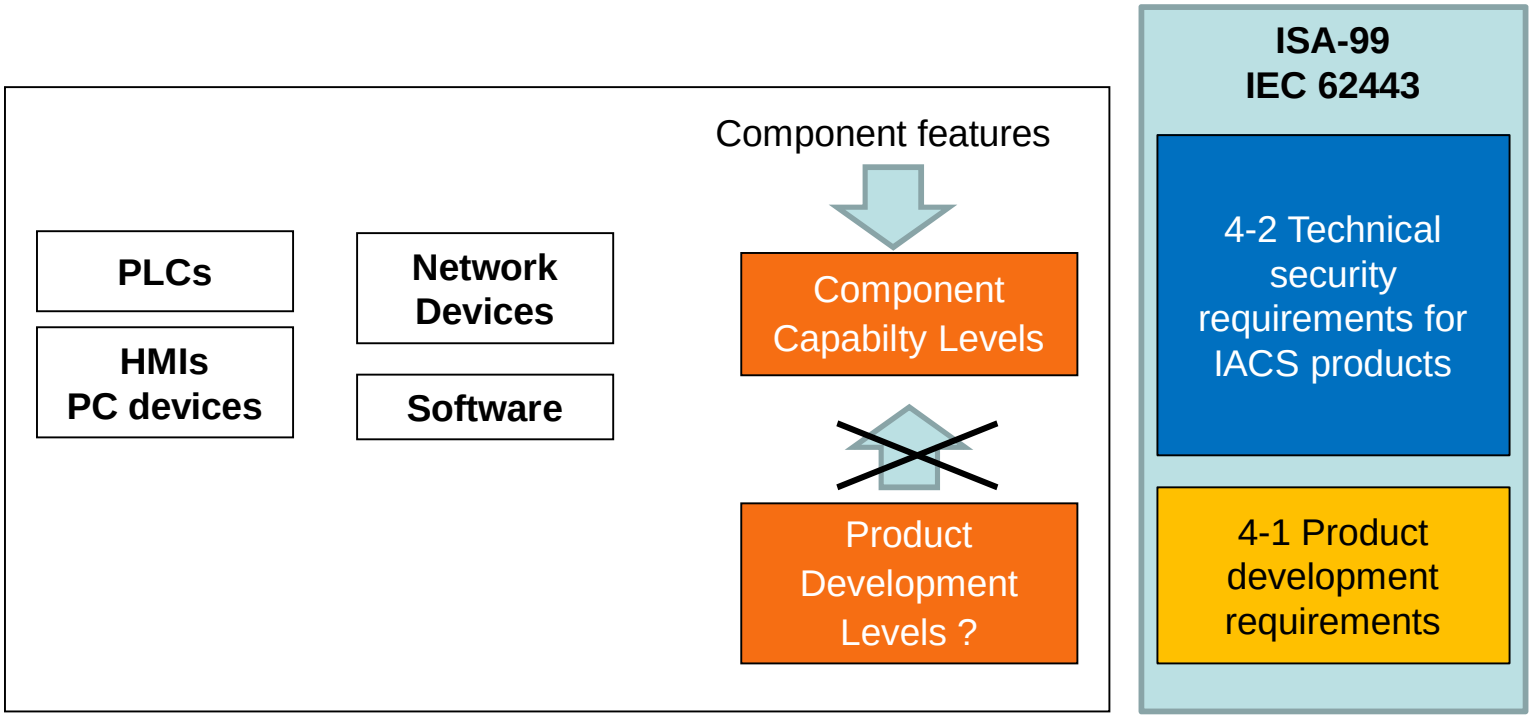
A requested capability SL does not require a given / minimum Component Capability Level of the Embedded Devices

There no direct relationship between Component Capability Levels and (System) Capability SLs

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Components Capability Levels are only defined by component features



Product development *levels* don't contribute to Component Capability Levels

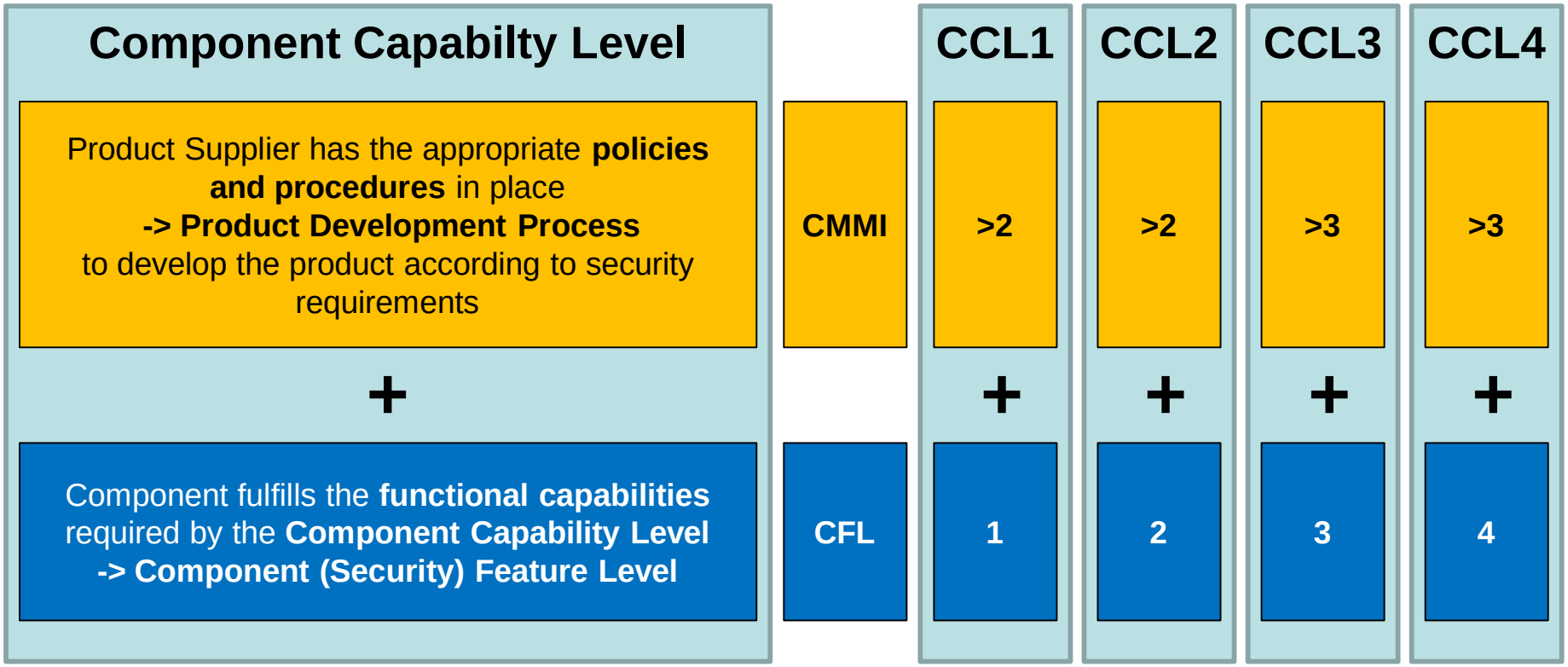
-> Proposal:

- **Specify the product development requirements without levels**
- **Follow the CMMI approach**

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Proposal for the assessment of Component Capability Levels



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

Outline

1. ISA-99 / IEC 62443 documents addressing policies and procedures vs. functional requirements

2. Assessment of protection levels of a plant
   - Solution vs. control system
   - Plant life cycle and product development
   - Requirements for the protection of a plant
   - The SLs concept is coherent for a solution and a control system
   - Proposal for Protection Levels (PLs)

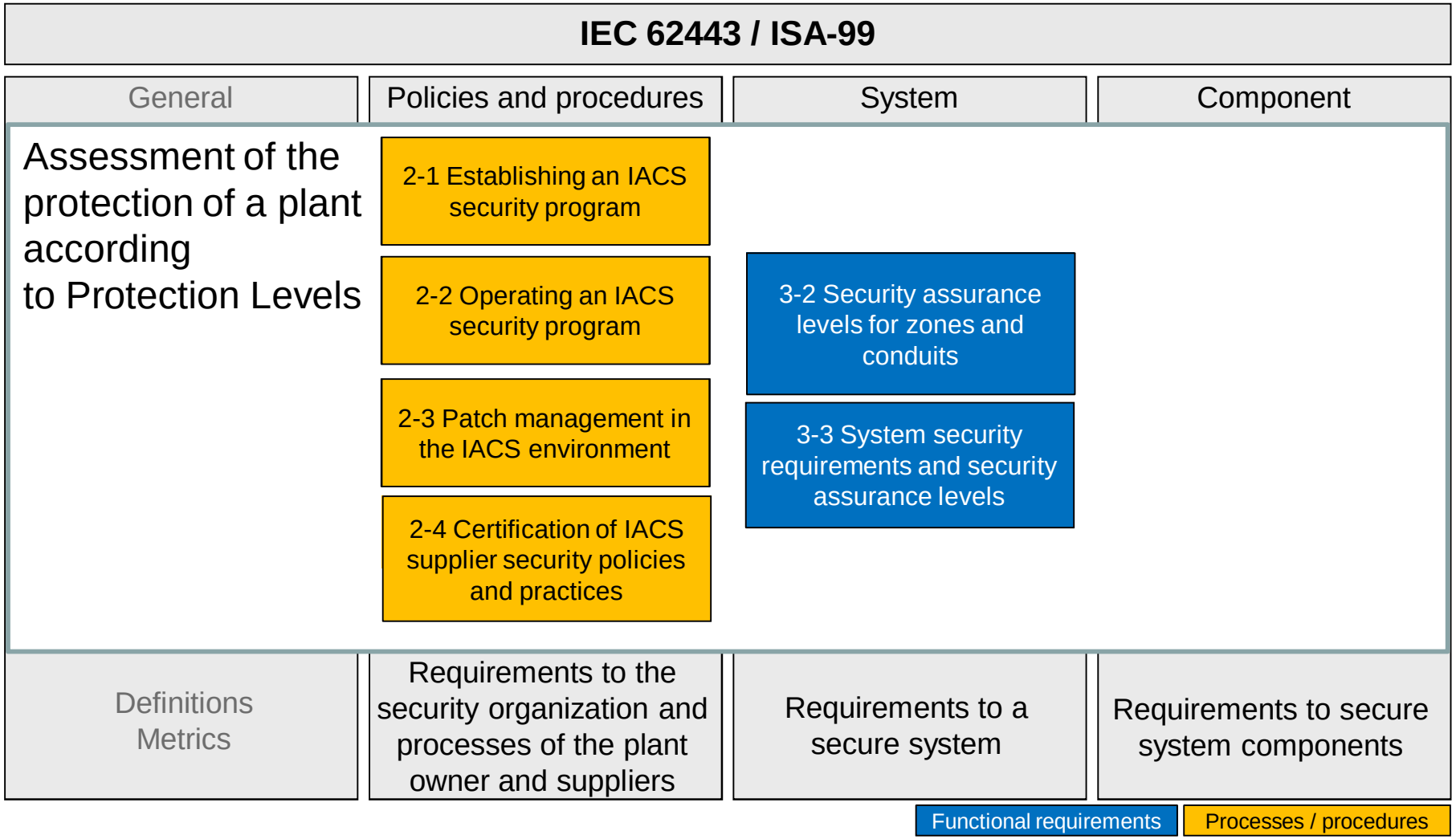
3. Assessment of security capabilities of control systems and components
   - No direct relationship between capability SLs and Component Capability Levels (CCL)
   - No contribution of levels of the Product Development Requirements to the CCL
   - Proposal for Componet Capability Levels (CCLs)

4. Summary if ISA-99 / IEC 62443 relevant document for the various assessments types

Pierre Kobes

Security Levels in ISA-99 / IEC 62443

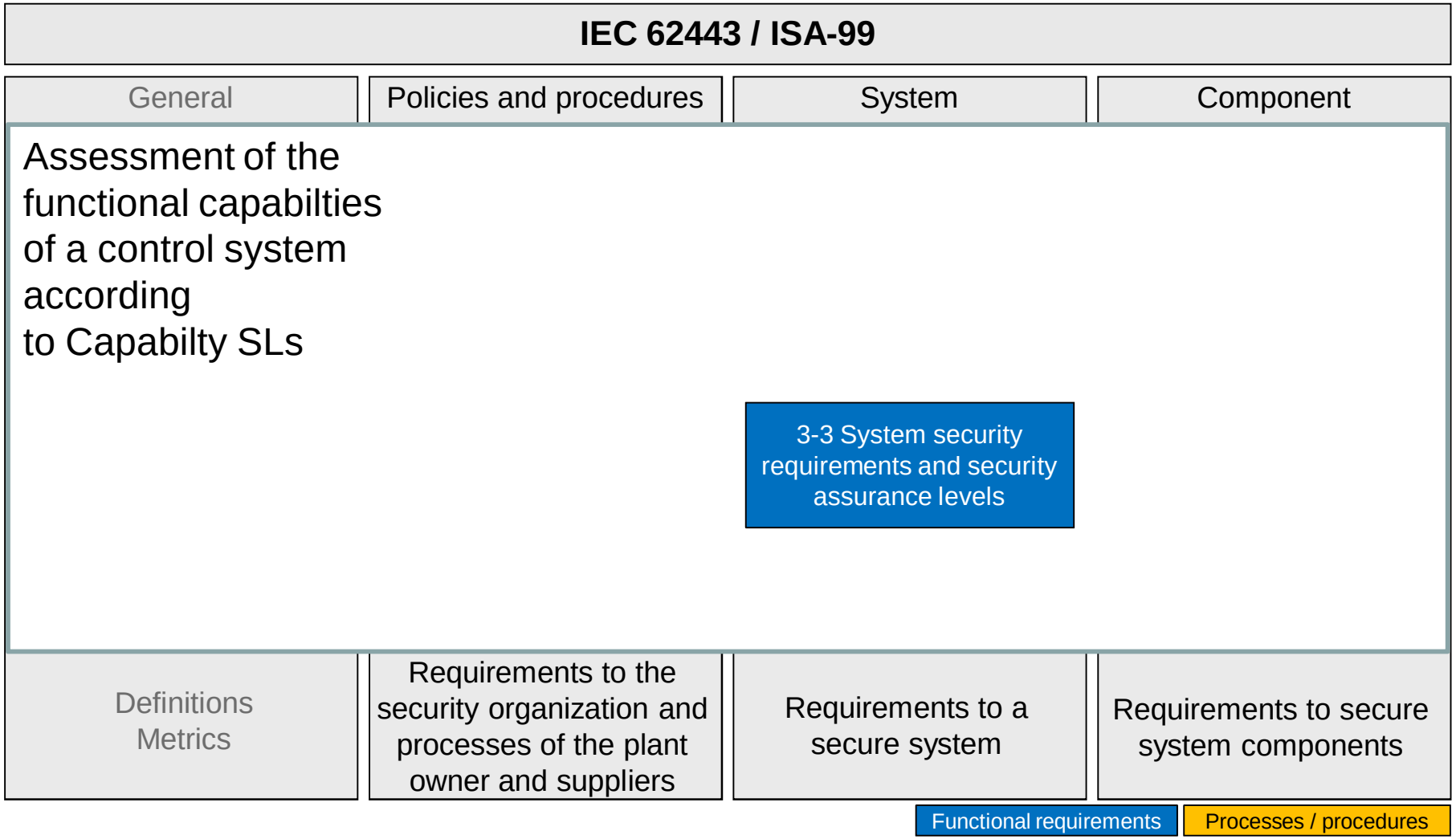
ISA-99 / IEC 62443 documents relevant for the assessment of the protection of a plant



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

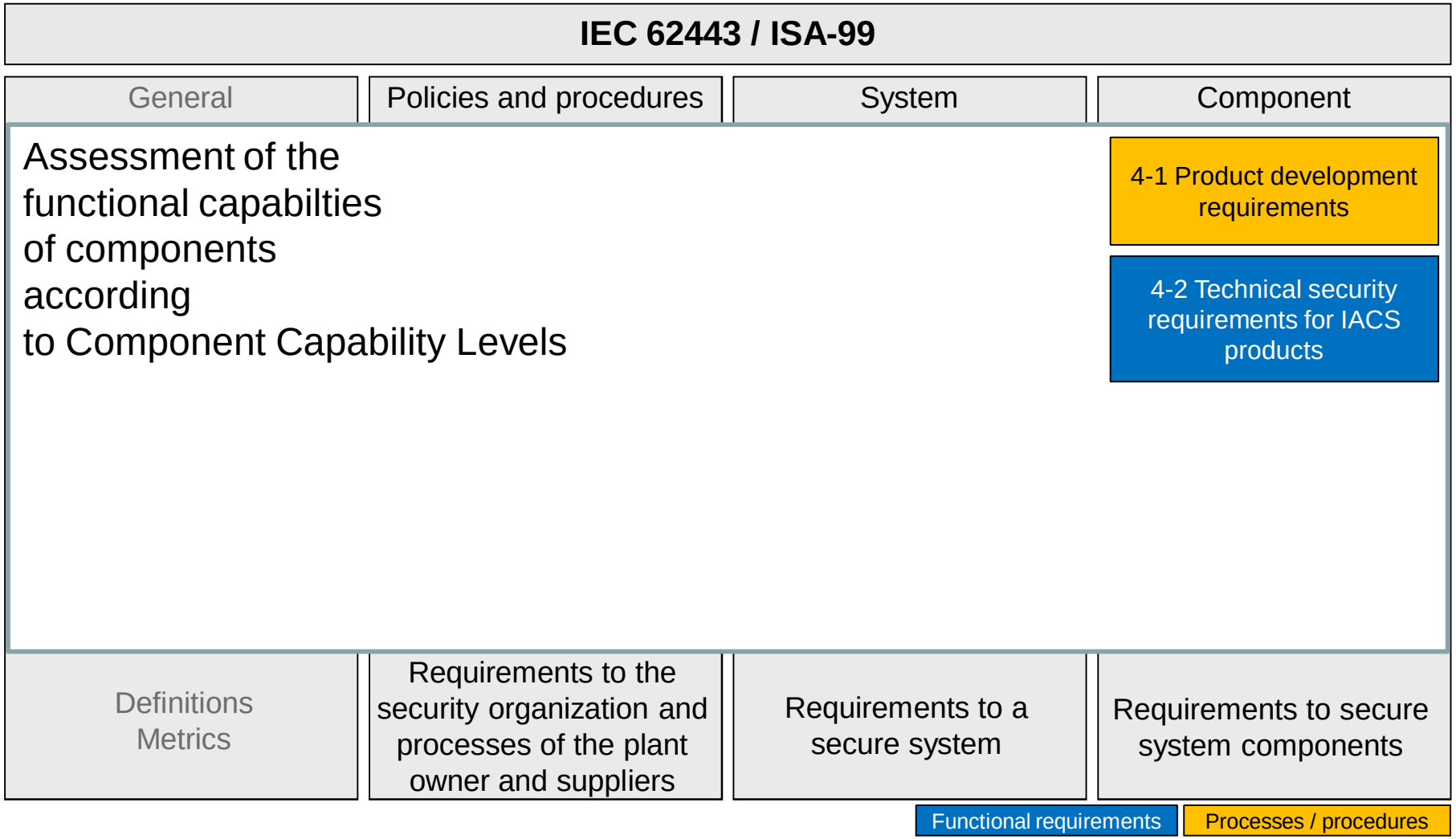
ISA-99 / IEC 62443 documents relevant for the assessment of the control system functional capabilities



Pierre Kobes

Security Levels in ISA-99 / IEC 62443

ISA-99 / IEC 62443 documents relevant for the assessment of the component functional capabilities



Pierre Kobes